

Threat Hunting: Hypothesis-Driven Analysis

What hunting is

Sitting back waiting for alerts is passive. Hunting = *actively* forming a hypothesis ('if an adversary used X, where would it appear?') and searching history for it.

The method

1. Hypothesis (based on a TTP or intel)
2. Build the search (telemetry + fields)
3. Analyze the hits (triage: real vs baseline)
4. Document (what did you learn? new detection?)
5. Repeat (make it a playbook/automated query)

Example hunts

'PowerShell download cradles in the last 90 days': process_creation with ParentImage powershell.exe and Image powershell.exe and Argument command-line containing 'DownloadString'

'LSASS unexpected handles': suspicion of credential theft – hunt handle-ops on lsass from odd PIDs

'New internal service connections 445/135' – lateral movement fingerprint

'machine with no 4769 but many files changed' – possible weird lateral antics

Enrich your hunt with EQL/KQL (language examples)

```
process where event.action == "ProcessCreate"
and process.parent.name in ("winword.exe", "excel.exe")
```

```
and process.name in ("powershell.exe","cmd.exe")
and process.command_line == "** -enc **"
```

Tools and data

EDR hunting UI (open search), Splunk/SOAR, Elastic, Velociraptor

Datasets: `EVTX-ATTACK-SAMPLES`, `MalwareBazaar`, clean baselines from your own lab

`Velociraptor` (open): live hunt across fleet endpoints

Honest triage

Fewer strong hits > many weak leads

Each hypothesis needs a 'kill' criterion (evidence it did NOT happen)

Not finding things is also a finding (document coverage)

Hunting is detective work with a hypothesis license. The hunt that finds nothing still sharpened your tools and your baseline.

← Behavioral Detection & Alert...

Automated Response & SOAR →